

ShopMate — Users & Authentication

Work log for 2026-09-28 (session 2): email verification, login, logout, styling, and a security fix.

What the `users` app does now

1. **Register:** a new account is created **inactive** and a verification email is sent.
2. **Verify:** the link in the email activates the account. It works only once.
3. **Login:** only verified (active) users can log in. Unverified users are told to check their email.
4. **Logout:** a CSRF-protected POST that clears the session (and so the cart).

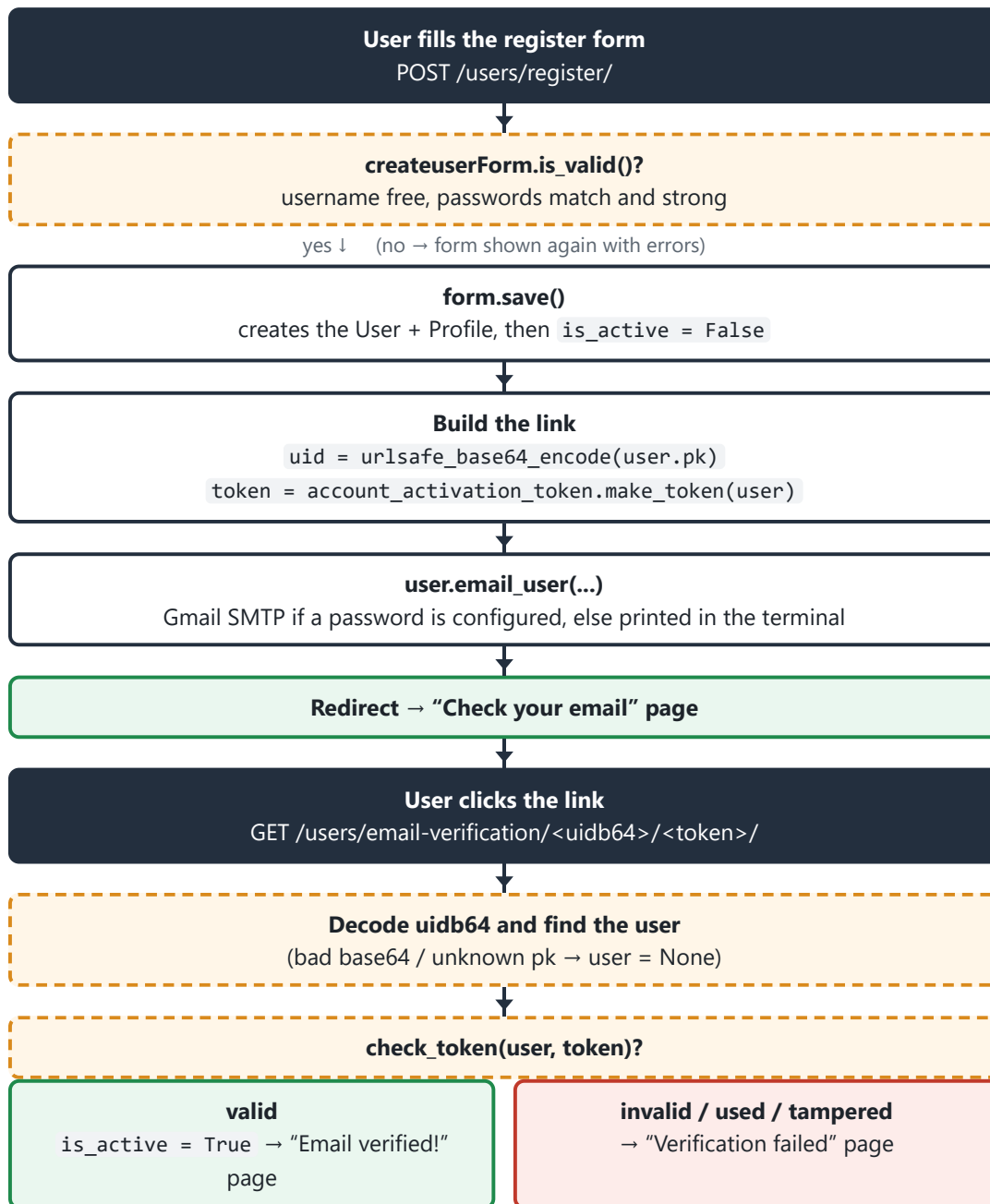
URLs (all under `/users/`)

URL	Name	View	Template
<code>register/</code>	register	<code>register</code>	register.html
<code>email-verification/<uidb64>/<token>/</code>	email_verification	<code>email_verification</code>	— (redirects)
<code>email-verification-sent/</code>	email_verification_sent	—	email_verification_sent.html
<code>email-verification-success/</code>	email_verification_success	—	email_verification_success.html
<code>email-verification-failed/</code>	email_verification_failed	—	email_verification_failed.html
<code>login/</code>	login	<code>login</code>	login.html (<i>restyled</i>)
<code>logout/</code>	logout	<code>User_logout</code>	logout.html (<i>new</i>)

Files changed in this session

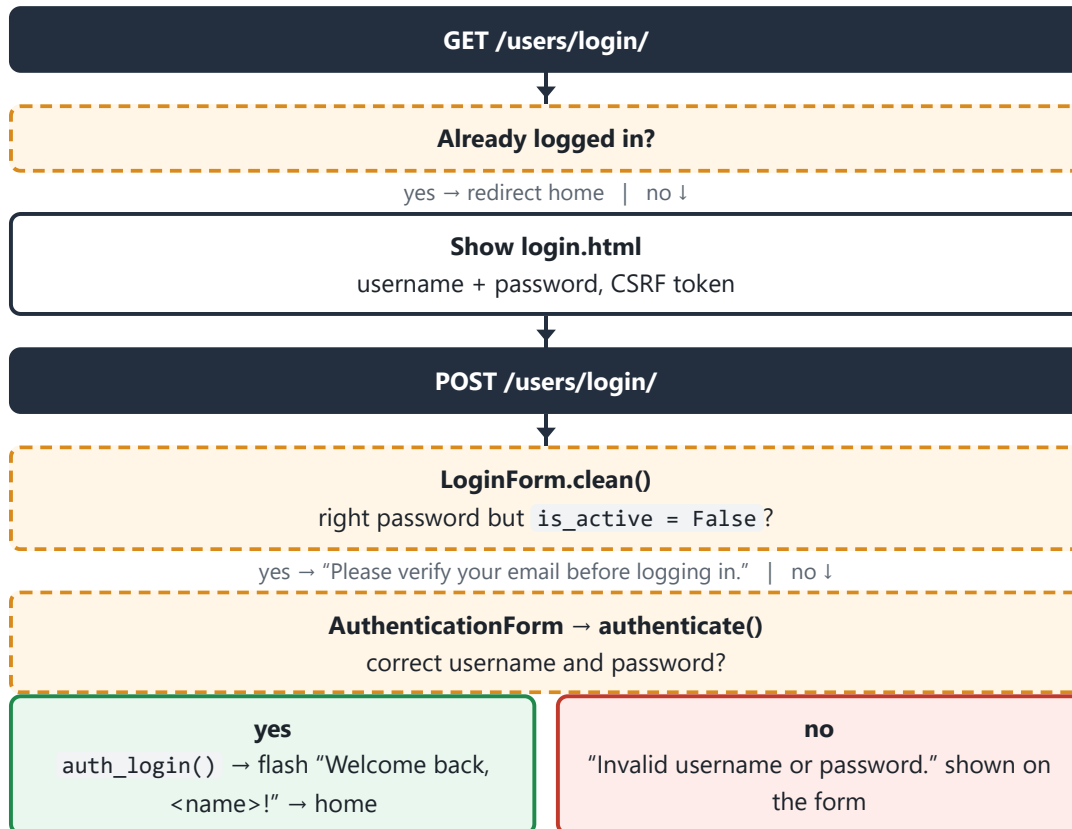
File	Change
<code>Ecom/settings.py</code>	Email password removed; read from env vars or <code>local_settings.py</code> . SMTP if a password is set, console otherwise. Added <code>LOGIN_URL</code> , <code>LOGIN_REDIRECT_URL</code> , <code>LOGOUT_REDIRECT_URL</code> .
<code>Ecom/local_settings.example.py</code>	New. Template for the git-ignored <code>local_settings.py</code> .
<code>.gitignore</code>	Ignores <code>local_settings.py</code> .
<code>users/views.py</code>	<code>email_verification</code> now activates users; <code>login</code> and <code>User_logout</code> added, with flash messages and detailed comments.
<code>users/forms.py</code>	<code>LoginForm</code> : Tailwind styling, element ids, friendly error messages, “verify your email” check.
<code>users/urls.py</code>	<code>login/</code> and <code>logout/</code> routes.
<code>users/templates/users/login.html</code>	New styled page that extends <code>base.html</code> .
<code>users/templates/users/logout.html</code>	New confirmation page (for a GET on <code>/users/logout/</code>).
<code>users/templates/users/register.html</code>	“Already have an account? Log in” link.
<code>MyEcom/templates/MyEcom/base.html</code>	Navbar: Login link or Logout button; the user icon shows “Hi, <name>” when logged in.
<code>users/tests.py</code>	9 tests covering register, verify, login and logout. All pass.

Flow 1 — Register and verify email



Why a link works only once: the token hash in `token.py` includes `user.is_active`. Once the account is activated the hash changes, so the same link fails the second time. It also expires after `PASSWORD_RESET_TIMEOUT` (3 days by default).

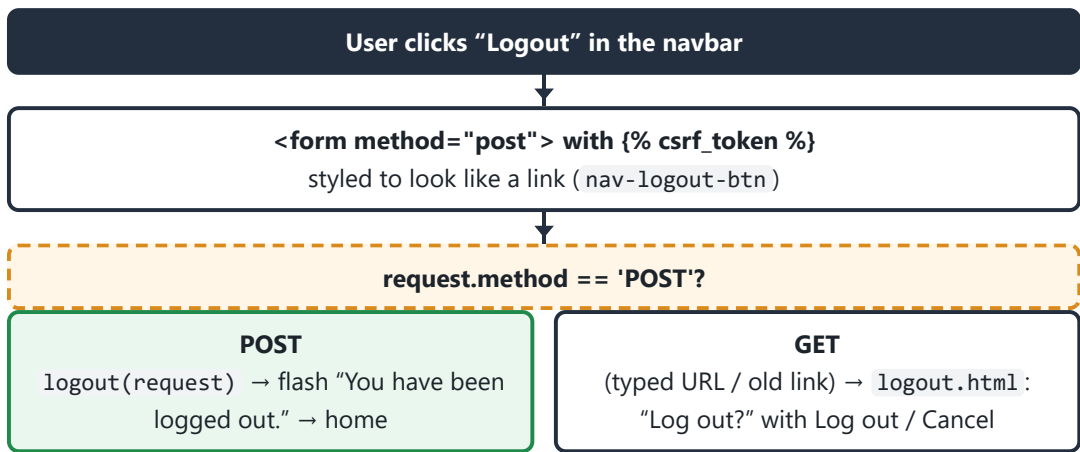
Flow 2 — Login



What changed from the first draft of the login view

- **No second `authenticate()`.** `AuthenticationForm.is_valid()` already authenticates the user; the view now just calls `form.get_user()`. The old `else: form.add_error(...)` branch could never run.
- **The GET form now gets `request: LoginForm(request)`,** as `AuthenticationForm` expects.
- **Unverified users get a clear message.** Django's `ModelBackend` returns `None` for inactive users, so they used to see "invalid password", which is confusing just after registering. The check only fires when the password is correct, so it doesn't reveal which usernames exist.
- **Styling:** the page extends `base.html` (it was a bare form with no navbar), uses the same dark card as the register page, and has ids: `login-card`, `login-form`, `login-username`, `login-password`, `login-btn`, `login-errors`, `login-register-link`.

Flow 3 — Logout and the navbar



Why POST and not a plain link? A GET logout can be triggered by any other website (for example ``). Django's own `LogoutView` became POST-only in Django 5.0 for this reason.

Logout empties the cart. `logout()` flushes the whole session, and the cart is stored in the session. The confirmation page says so. Keeping the cart would need it copied into the new session or saved in the database (a future task).

Navbar (base.html)

State	Top bar	User icon area
Logged out	"Login" link (nav-login-link)	 links to the login page (nav-user-link)
Logged in	"Logout" button (nav-logout-form / nav-logout-btn)	"  Hi, <first name or username> " (nav-username)

The welcome and logout messages use the flash-message box already in `base.html` (green, fades after 1 second).

Security fix and the tricky parts

1. The Gmail app password was written in `settings.py`. The GitHub repo is public, so committing it would have leaked the account. It was never committed, so nothing has leaked.

Fix: `settings.py` now reads `EMAIL_HOST_USER` / `EMAIL_HOST_PASSWORD` from environment variables and then imports `Ecom/local_settings.py` if it exists. That file is in `.gitignore`; `local_settings.example.py` shows the format. With no password configured, emails go to the terminal, so the project still runs on any machine.

2. `email_verification` could crash on a tampered link

`urlsafe_base64_decode()` was called *before* the `try`, so a bad `uidb64` raised an uncaught `ValueError` (a 500 error page). Decoding moved inside the `try`; any failure now goes to the “Verification failed” page. The failure paths also all redirect now (one used to render the template directly).

3. The login page had no navbar or site styling

`login.html` didn’t use `{% extends 'MyEcom/base.html' %}`, so it rendered as a bare form on a white page.

`LoginForm` also used the Bootstrap class `form-control`, which does nothing here because the site uses Tailwind.

4. Logout was a GET link

See Flow 3: it is now a CSRF-protected POST, and a GET shows a confirmation page.

Tests — `users/tests.py` (run: `env\Scripts\python.exe manage.py test`)

Test	Checks
register creates inactive user	redirect to “sent”, <code>is_active=False</code> , one email containing the link
valid link activates once	success redirect, user active, second use → failed
tampered link fails	bad base64 → failed page, no crash
login page renders / success / wrong password	form shown; login + welcome message + Logout in navbar; error, no session
unverified user	“Please verify your email...” and not logged in
logout GET / POST	GET shows confirmation and stays logged in; POST logs out with a message

Result: 9 tests, all passing. `manage.py check`: no issues.

Next session

1. Create `Ecom/local_settings.py` from the example so real emails send again.
2. Handle products deleted while they are in a cart.
3. Decide whether “Add to Cart” adds to the quantity or replaces it.
4. Optional: keep the cart across login/logout; “forgot password”; resend verification email.
5. Delete the local test users (`testuser_active_check`, `viewtest_user`, `viewtest_user2`).